



Trường ĐH Công nghệ Thông tin –
ĐHQG TP. HCM

Cơ chế hoạt động của mã độc

NT230 – Malware's Modus Operandi



**WELCOME
BACK
AND
GOOD LUCK
THIS SEMESTER**





NT230 - Cơ chế hoạt động của mã độc



Bài giảng lý thuyết – 02.2025
Email: duypt@uit.edu.vn

Buổi 01 – Tổng quan về mã độc



- **Sơ lược về môn học:** “Cơ chế hoạt động của mã độc”
 - Số tín chỉ: 02 lý thuyết + 01 thực hành
 - Môn học: Cơ sở ngành – Ngành An toàn thông tin
- **Giảng viên lý thuyết:**
 - TS. Phạm Văn Hậu
 - ThS. Phan Thế Duy
- **Giảng viên thực hành:**
 - ThS. Nghi Hoàng Khoa
 - KS. Ngô Đức Hoàng Sơn
 - CN. Trương Thị Hoàng Hảo

before
we begin

Trước khi chúng ta bắt đầu ...



Khảo sát kiến thức



Mã độc (Malware) là gì?

Khảo sát kiến thức



Các nguyên nhân bị lây nhiễm mã độc?

Khảo sát kiến thức



RANSOMWARE



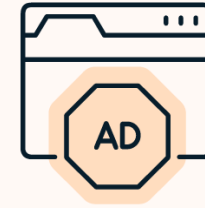
Blackmails you

SPYWARE



Steals your data

ADWARE



Spams you with ads

Types of Malware

WORMS



Spread
across computers

TROJANS



Sneak malware
onto your PC

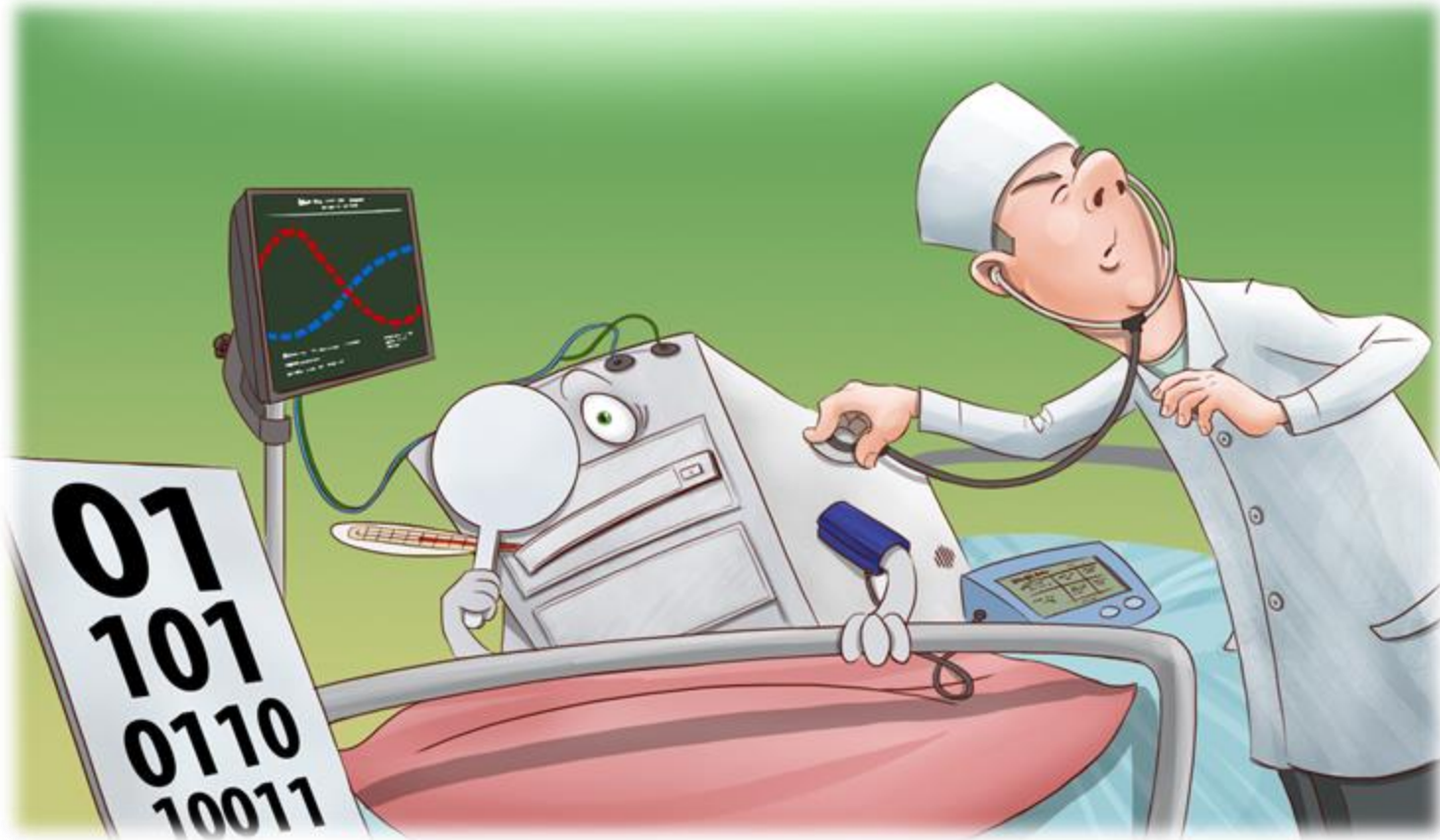
BOTNETS



Turn your PC
into a zombie

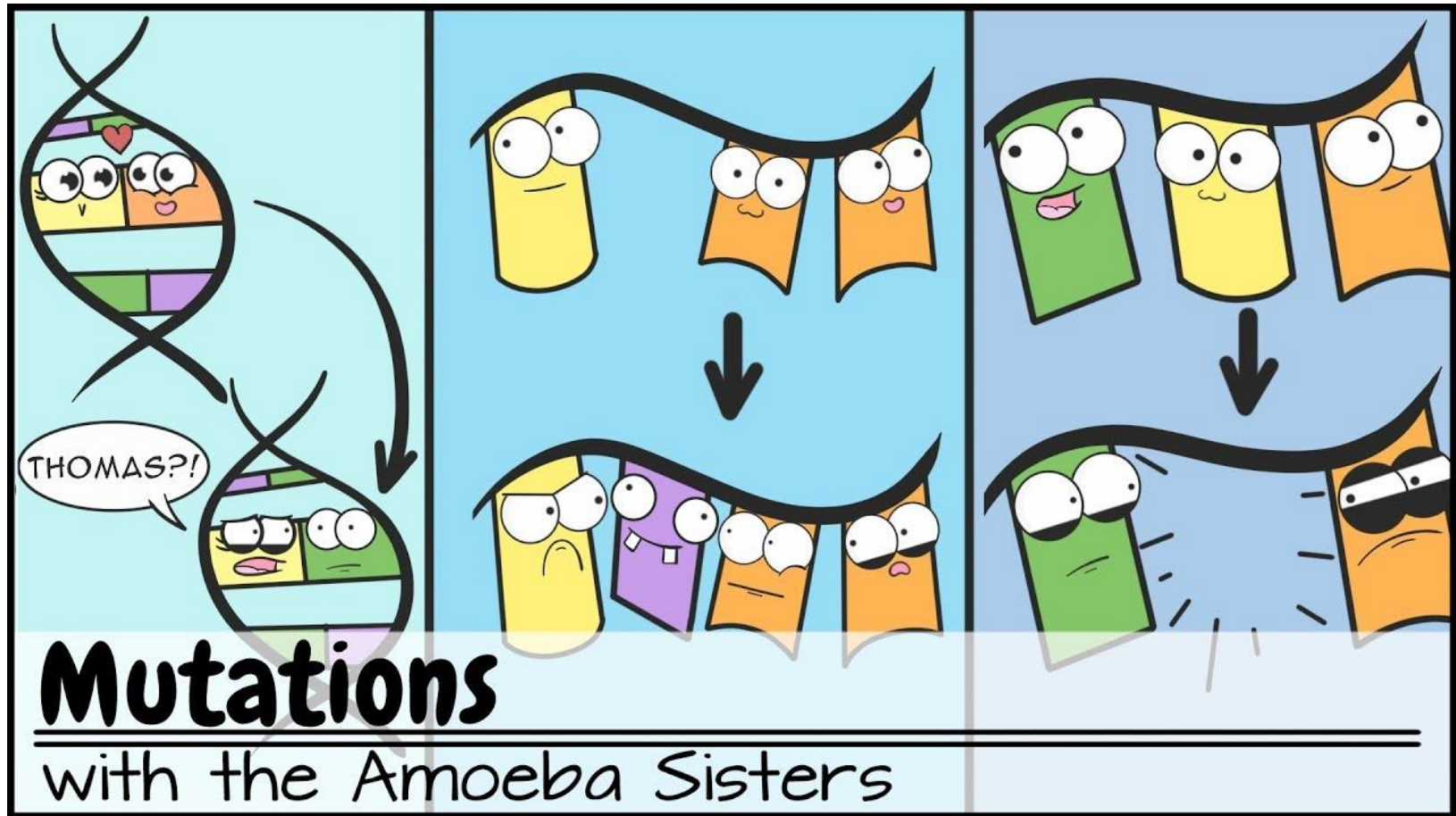
Bạn đã từng bị nhiễm loại mã độc nào chưa?

Khảo sát kiến thức



Các dấu hiệu bị lây nhiễm mã độc?

Khảo sát kiến thức



Phương pháp biến đổi của mã độc đột biến?

Khảo sát kiến thức



Phương pháp nào giúp xác định, phân tích và ngăn chặn, loại bỏ mã độc?

Khảo sát kiến thức



- Mã độc
- Virus máy tính
- Sâu máy tính (worm)
- Phần mềm lừa đảo
- Rootkit
- Macro virus
- Mã độc đột biến
- Trojan
- Botnet
- Hoạt động & cơ chế lây nhiễm của mã độc
- Cơ chế trốn tránh phát hiện



- **Mục tiêu:**

Trang bị những kiến thức cơ bản về cơ chế hoạt động của các loại mã độc, phần mềm độc hại, virus máy tính, sâu máy tính.





Career path

Cơ hội việc làm liên quan



- **Kỹ sư Phân tích Mã độc (Malware Analyst):** tập trung vào việc đối phó với các mối đe dọa và chiến thuật tấn công phổ biến.
 - *Phân tích và điều tra phần mềm độc hại để xác định cách thức hoạt động, mục tiêu và phương pháp lây nhiễm.*
 - *Sử dụng công cụ chuyên dụng như IDA Pro, Ghidra, YARA, Volatility, ... để reverse engineering mã độc.*
 - *Trích xuất các chỉ số xâm nhập (IOCs - Indicators of Compromise). Các IOC này sau đó có thể được đưa vào hệ thống quản lý sự kiện và thông tin bảo mật (SIEMs), nền tảng tình báo mối đe dọa (TIPs) và các công cụ điều phối bảo mật, giúp cảnh báo các nhóm an ninh về các mối đe dọa liên quan trong tương lai.*
 - *Viết báo cáo, cảnh báo bảo mật và đề xuất biện pháp phòng chống.*
 - *Nơi làm việc: Trung tâm an ninh mạng, SOC (Security Operations Center), tổ chức nghiên cứu bảo mật.*

- **Chuyên gia Phân tích Mối đe dọa (Threat Intelligence Analyst):**

- *Theo dõi, thu thập thông tin về các chiến dịch tấn công và nhóm hacker (APT, ransomware, botnet).*
- *Phân tích các mẫu mã độc để tìm hiểu về chiến thuật, kỹ thuật và quy trình (TTPs) của kẻ tấn công.*
- *Cung cấp thông tin tình báo để hỗ trợ phòng thủ và ứng phó sự cố.*
- *Nơi làm việc: Công ty bảo mật, tổ chức chính phủ, trung tâm điều phối an ninh mạng (CERT, CSIRT).*

- **Chuyên gia Chuyên viên Điều tra Ứng phó Sự cố (Incident Response Analyst / Forensics Investigator):**

- *Phát hiện và điều tra các cuộc tấn công mạng liên quan đến mã độc.*
- *Thực hiện digital forensics để truy vết nguồn gốc và phương thức tấn công.*
- *Sử dụng công cụ như Volatility, Autopsy, Wireshark, Splunk để phân tích dấu vết trong hệ thống.*
- *Nơi làm việc: Đội ngũ bảo mật doanh nghiệp, công ty điều tra bảo mật (các công ty cung cấp dịch vụ như Mandiant, CrowdStrike).*

- **Chuyên gia Đánh giá Bảo mật (Penetration Tester / Red Team):**

- *Sử dụng kỹ thuật malware evasion để kiểm tra khả năng phòng thủ của hệ thống.*
- *Viết mã độc thử nghiệm (custom malware) để đánh giá hệ thống chống xâm nhập.*
- *Mô phỏng tấn công APT, sử dụng các công cụ chuyên dụng thí dụ như Cobalt Strike, Metasploit,...*
- *Nơi làm việc: Nhóm Red Team của tổ chức, công ty pentest, MSSP (Managed Security Service Provider).*

- **Kỹ sư Bảo mật (Security Engineer):**

- *Xây dựng hệ thống bảo mật chống lại malware và các cuộc tấn công mạng.*
- *Phát triển các giải pháp Endpoint Detection & Response (EDR), SIEM, IDS/IPS.*
- *Cấu hình và tối ưu firewall, antivirus, threat hunting.*
- *Nơi làm việc: Doanh nghiệp lớn, ngân hàng, tổ chức tài chính, công ty bảo mật.*

- **Chuyên gia nghiên cứu bảo mật (Security Researcher):**

- *Nghiên cứu và khám phá lỗ hổng bảo mật liên quan đến mã độc.*
- *Nghiên cứu các phương pháp phát hiện và cơ chế trốn tránh của mã độc để nâng cao nhận thức của cộng đồng nghiên cứu mã độc.*
- *Viết báo cáo kỹ thuật, công bố CVE, đóng góp vào cộng đồng bảo mật.*
- *Phát triển công cụ phân tích malware mã nguồn mở.*
- *Nơi làm việc: Các phòng thí nghiệm bảo mật ; hoặc làm việc tự do.*

- **Chuyên viên Phân tích Rủi ro & Tuân thủ (Risk Analyst / Compliance Specialist):**

- *Đánh giá rủi ro liên quan đến mã độc trong doanh nghiệp.*
- *Đảm bảo hệ thống tuân thủ các tiêu chuẩn bảo mật như ISO 27001, NIST, GDPR,...*
- *Xây dựng chính sách bảo vệ chống lại mã độc cho tổ chức.*
- *Nơi làm việc: Công ty tư vấn bảo mật, doanh nghiệp lớn có yêu cầu tuân thủ nghiêm ngặt.*



Nội dung bài giảng của môn học

Lectures by Sessions



Nội dung môn học (2024-2025)



- Các khái niệm tổng quan về mã độc máy tính
- Cấu trúc tập tin thực thi (PE- Portable Exe) + Windows Internal
- Virus máy tính
 - Định nghĩa, khái niệm về virus máy tính
 - Một số dạng virus lây nhiễm qua tập tin: Chèn payload (Code and Process Injection), DLL Injection, Process Hollowing, ...
- Sâu máy tính (worm)
- Botnet/ APT malware
- Stealth Malware: Các kỹ thuật mã hóa (encrypted), rồi mã (obfuscation) của mã độc
 - Encrypted/packed virus: Packing/unpacking, Decryptor, Protector
 - Đột biến mã độc: Polymorphic (Đa hình), Oligomorphic (Dị hình), Metamorphic (Siêu hình)

Nội dung môn học (2024-2025)



- Stealth and Evasive Malware: Các kỹ thuật chống phân tích (Armoring Techniques):
 - Anti-Disassembly
 - Anti-Debugging
 - Anti-VM & Anti-Sandbox
- Stealth and Evasive Malware: Các phương pháp chống phát hiện (Evasion Techniques):
 - Anti-Virus Evasion
 - IDS/EDR Evasion
 - Sandbox Evasion
- Mã độc phi tập tin (Fileless Malware)
- Ransomware & Ransomware-as-a-Service (RaaS)
- Macro Malware & Rootkit

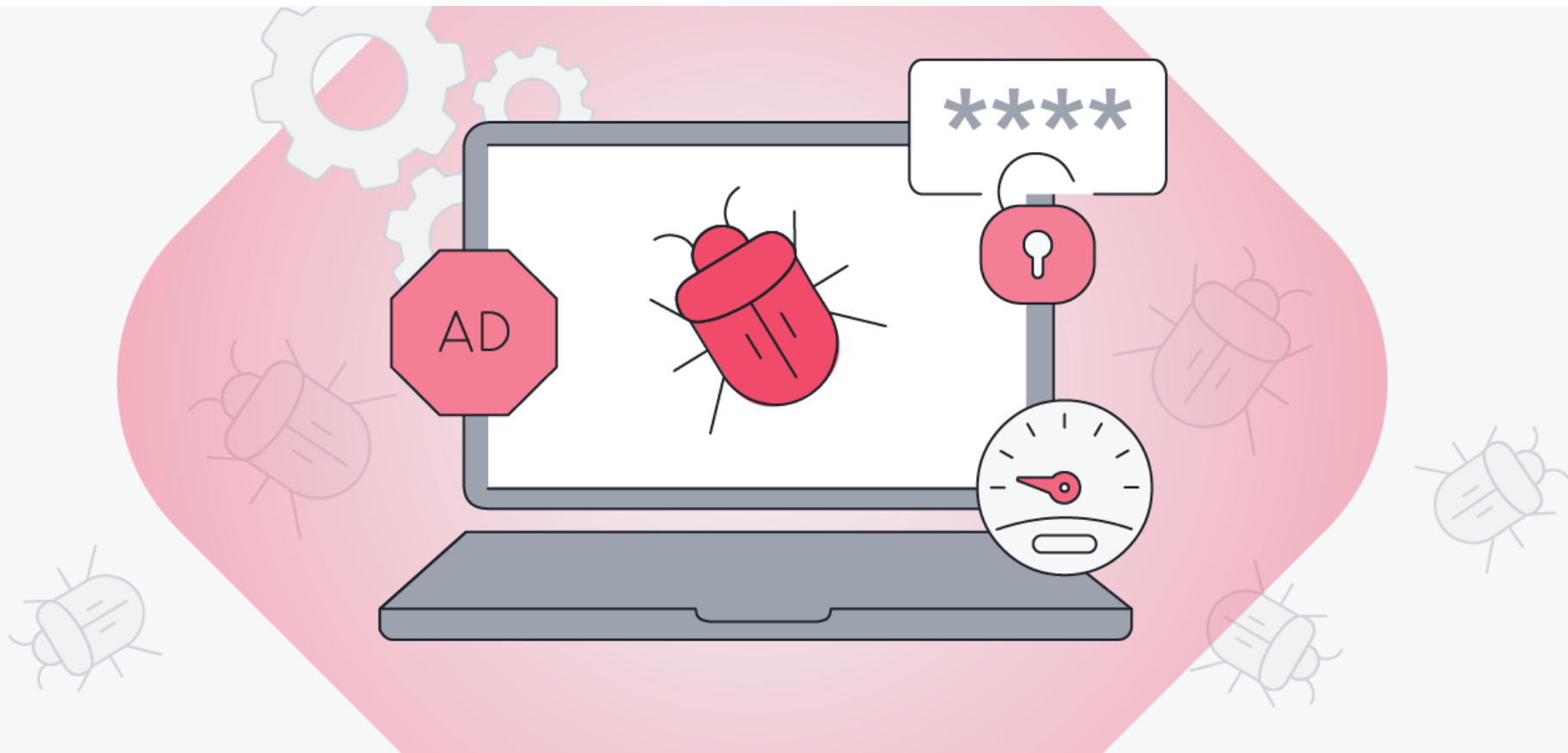
Đánh giá môn học: Quá trình

Bài tập, các chủ đề nâng cao

- Quiz: các câu hỏi về nội dung bài học (cá nhân)
- Assignment (bài tập): nhóm/cá nhân
- Project (đồ án): 01 chủ đề seminar (nhóm)



Đánh giá môn học: Thực hành



6 buổi thực hành về các nội dung liên quan

- Làm theo nhóm đồ án đã đăng ký
- Tất cả các thành viên đều tham gia

Đánh giá môn học: Cuối kỳ



Cách đánh giá bao gồm:

- Thi lý thuyết (Trắc nghiệm + Tự luận): 90 phút
 - Tự luận: (4đ)
 - ✓ Kiến thức cơ bản và vận dụng: **02 câu**
 - ✓ Mô tả đồ án môn học: **01 câu**
 - Trắc nghiệm (6đ): **40 câu hỏi** (4 lựa chọn)

Yêu cầu



- Đến lớp đúng giờ
- Thành viên nhóm:
 - **Tối đa 03 thành viên (lớp tài năng)**
 - **Tối đa 04 thành viên (lớp chính quy)**
- Tìm hiểu trước bài giảng + Tích cực thảo luận
- Bài tập + câu hỏi trên lớp + Đồ án: Điểm quá trình **(25%)**
- Cuối kỳ: **50%**
- Làm nhóm (đối với thực hành): **(25%)**

Các công cụ hỗ trợ



- IDA Pro
- OllyDBG
-

- Ghidra
- WinDbg
-



Top 20 các công cụ phân tích mã độc



Malware Analysis Tools



- The Top 20 Malware Analysis Tools for 2025 (Nguồn: <https://www.stationx.net/malware-analysis-tools/>)
- [Top 10 Malware Analysis Platforms & Tools - SOCRadar® Cyber Intelligence Inc.](#)

- Cài đặt các công cụ hỗ trợ trên máy ảo
- Cảnh giác với các phần mềm, công cụ phiên bản crack
- Thực hiện các thao tác, chỉnh sửa mã độc trên máy ảo
- **KHÔNG NÊN** sử dụng môi trường máy thật cá nhân.
 - FLARE VM - The Windows Malware Analysis Distribution

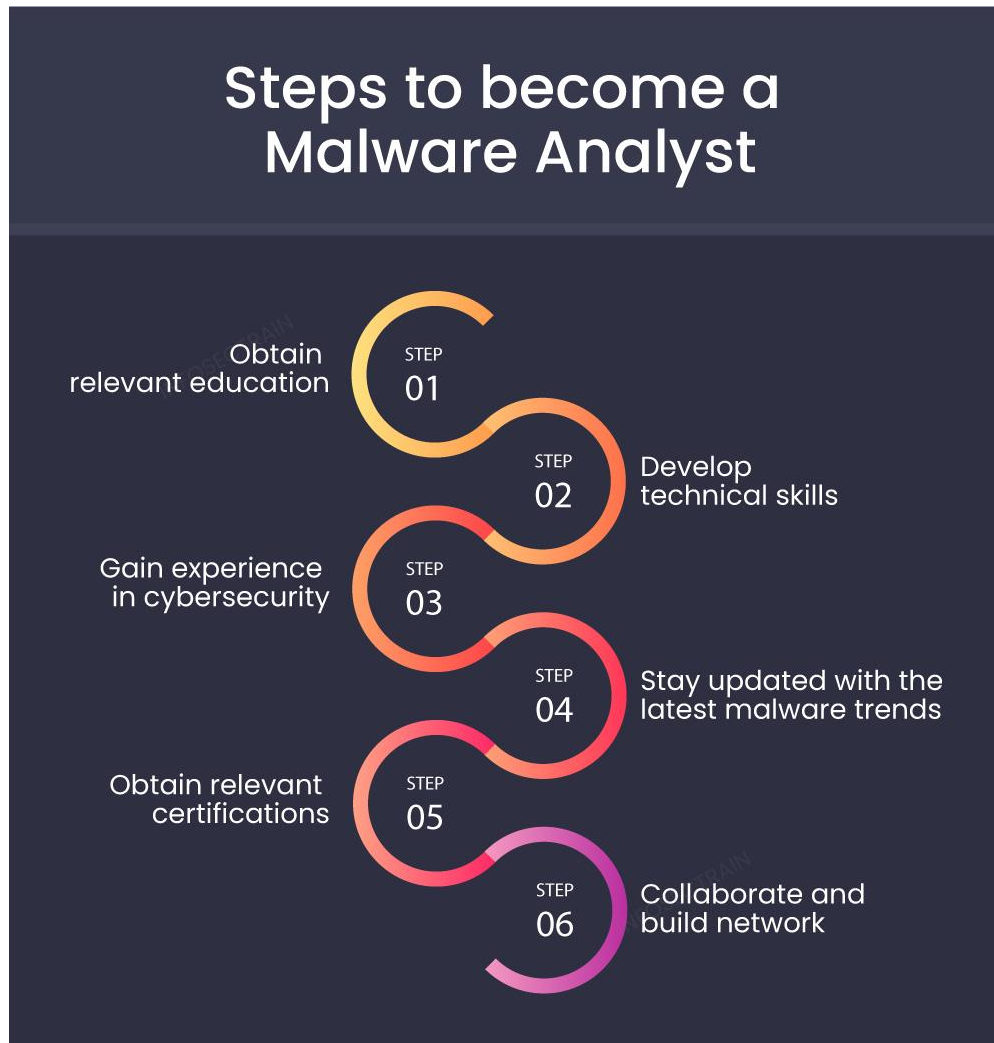


Lộ trình trở thành Chuyên viên Phân tích mã độc

Malware Analyst Roadmap



Lộ trình học và trở thành Malware Analyst



[Nguồn: How to become a Malware Analyst? - InfosecTrain](#)

Lộ trình học và trở thành Malware Analyst



- Nếu bạn mới bắt đầu, hãy tập trung vào **hệ điều hành, phân tích động và tĩnh**.
- Nếu bạn đã có kiến thức cơ bản, hãy học **reverse engineering, memory forensics**.
- Muốn chuyên sâu, hãy rèn luyện thực tế với mã độc thực tế (**malware samples**), phân tích trong hộp cát (**sandbox analysis**).

Lộ trình học và trở thành Malware Analyst



- Một số chứng chỉ chuyên môn:
 - 🏆 GREM – GIAC Reverse Engineering Malware
 - 🏆 OSCP – Offensive Security Certified Professional
 - 🏆 GXPN – GIAC Exploit Researcher and Advanced Penetration Tester



Bài 01: Tổng quan về mã độc

L01: Introduction to Malware

Tổng quan về mã độc



Mã độc (Malware) là gì?

Mã độc: Định nghĩa



- **Malware** (**Mal**icious Soft**ware**) là một thuật ngữ chung dùng để chỉ bất kỳ loại phần mềm độc hại nào được thiết kế nhằm gây hại hoặc khai thác thiết bị, dịch vụ hoặc mạng có thể lập trình được.
- Tội phạm mạng thường sử dụng malware để trích xuất dữ liệu mà chúng có thể lợi dụng nhằm trục lợi tài chính.

Tổng quan về mã độc: Cơ chế hoạt động



what are other
words for
modus operandi?



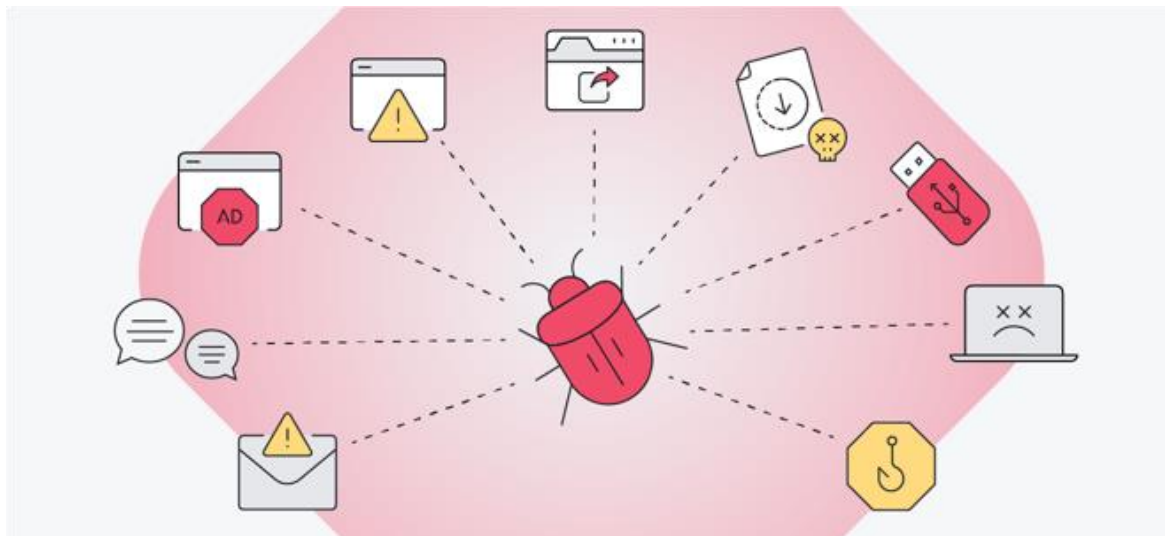
procedure, way, system,
technique, method, plan, manner,
approach, mode, routine



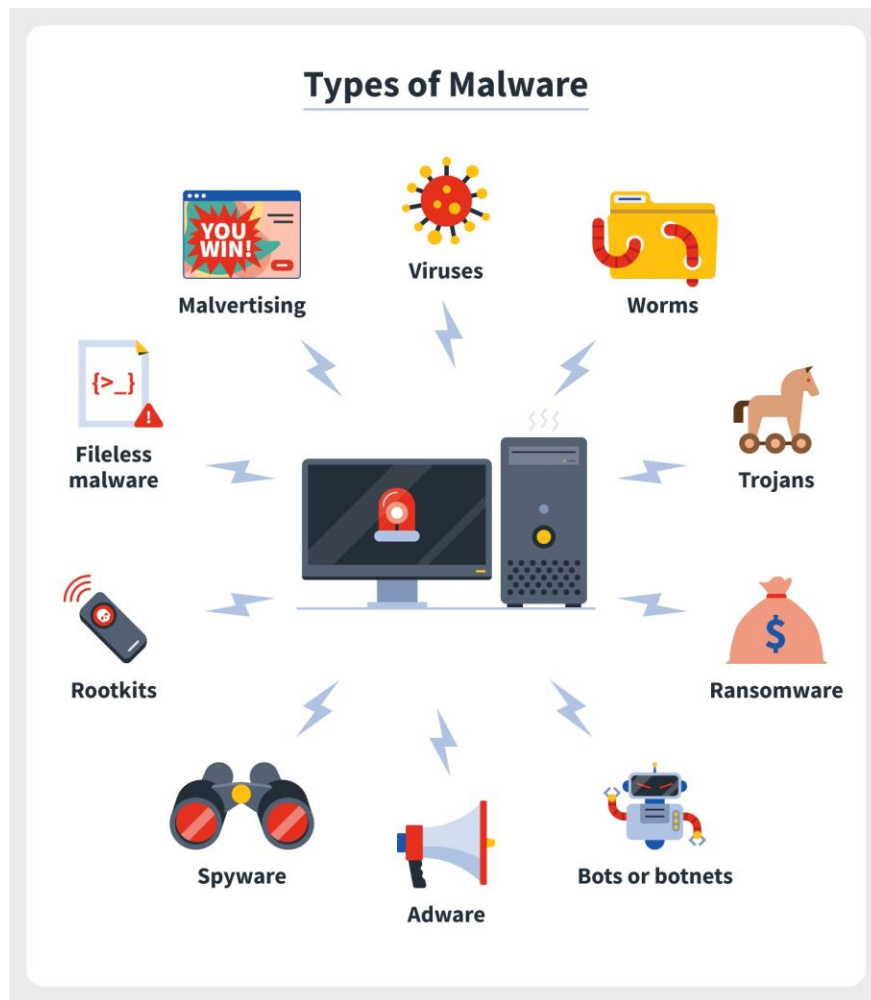
Các kỹ thuật phát tán và lây nhiễm



- Email
- Ứng dụng nhắn tin
- Quảng cáo nhiễm độc (Malvertising)
- Cửa sổ cảnh báo giả mạo (Scareware)
- Tải xuống tự động (Drive-by Download)
- Thiết bị lưu trữ ngoài (USB, ổ cứng di động)
- Khai thác lỗ hổng (Exploits)
- Tấn công lừa đảo (Phishing & Quishing)
- Cài đặt thủ công (Personal Installation)



Các loại mã độc: Sơ lược



Các thể loại của mã độc?

Các loại mã độc: Virus



- **Virus máy tính (computer virus):**
 - Định nghĩa: Mã độc có khả năng tự gắn vào tệp tin hợp pháp và lây lan khi tệp đó được thực thi.
 - Tính chất: Thường yêu cầu sự tương tác của người dùng để kích hoạt (mở tệp, chạy chương trình).
 - Nguyên nhân lây nhiễm: Tải phần mềm không rõ nguồn gốc, mở tệp đính kèm email độc hại.

Các loại mã độc: Worm



- **Sâu máy tính (computer worm):**
 - Định nghĩa: Mã độc tự nhân bản và lây lan qua mạng mà không cần tệp chủ.
 - Tính chất: Phát tán nhanh chóng, có thể làm tê liệt hệ thống mạng.
 - Nguyên nhân lây nhiễm: Lỗ hổng bảo mật trong hệ điều hành hoặc phần mềm mạng (SMB, RDP,...).

Các loại mã độc: Trojan



- **Trojan (Ngựa thành Troy):**
 - Định nghĩa: Phần mềm giả mạo ứng dụng hợp pháp nhưng có chức năng độc hại.
 - Tính chất: Không tự sao chép nhưng có thể tạo cửa hậu (backdoor) cho hacker.
 - Nguyên nhân lây nhiễm: Tải xuống phần mềm bẻ khóa, ứng dụng lậu, email giả mạo.

Các loại mã độc: Ransomware



- **Ransomware (Mã độc tổng tiền):**
 - Định nghĩa: Mã độc mã hóa dữ liệu và yêu cầu tiền chuộc để giải mã.
 - Tính chất: Hạn chế quyền truy cập dữ liệu, thường sử dụng thuật toán mã hóa mạnh.
 - Nguyên nhân lây nhiễm: Tấn công qua email phishing, lỗ hổng RDP, tải phần mềm độc hại,...

Các loại mã độc: Spyware



- **Spyware (Phần mềm gián điệp):**
 - Định nghĩa: Phần mềm gián điệp theo dõi hoạt động của người dùng mà không có sự đồng ý.
 - Tính chất: Thu thập thông tin như mật khẩu, lịch sử duyệt web, vị trí GPS...
 - Nguyên nhân lây nhiễm: Cài đặt phần mềm miễn phí kèm theo spyware, quảng cáo độc hại.

Các loại mã độc: Adware



- **Adware (Mã độc hiển thị quảng cáo):**
 - Định nghĩa: Mã độc hiển thị quảng cáo không mong muốn trên trình duyệt hoặc ứng dụng.
 - Tính chất: Không gây hại trực tiếp nhưng có thể làm chậm hệ thống và thu thập dữ liệu.
 - Nguyên nhân lây nhiễm: Cài đặt phần mềm miễn phí có kèm quảng cáo, extension độc hại trên trình duyệt.

Các loại mã độc: Rootkit



- **Rootkit:**

- Định nghĩa: Mã độc cho phép kẻ tấn công kiểm soát hệ thống mà không bị phát hiện.
- Tính chất: Hoạt động ở mức kernel hoặc user mode, khó bị phát hiện bởi antivirus.
- Nguyên nhân lây nhiễm: Lỗi hỏng bảo mật, phần mềm không rõ nguồn gốc, tấn công firmware,...

Các loại mã độc: Backdoor



- **Backdoor (Cửa hậu):**

- Định nghĩa: Tạo cửa hậu để kẻ tấn công truy cập vào hệ thống từ xa mà không cần xác thực.
- Tính chất: Thường được kết hợp với trojan hoặc rootkit để ẩn giấu.
- Nguyên nhân lây nhiễm: Lỗi hồng bảo mật, phishing, khai thác dịch vụ từ xa.

Các loại mã độc: Keylogger



- **Keylogger:**

- Định nghĩa: Mã độc ghi lại thao tác bàn phím để đánh cắp thông tin đăng nhập.
- Tính chất: Có thể ghi lại mật khẩu, số thẻ tín dụng, tin nhắn riêng tư...
- Nguyên nhân lây nhiễm: Tải phần mềm độc hại, phishing, sử dụng máy tính công cộng bị nhiễm keylogger...

Các loại mã độc: Fileless Malware



- **Fileless Malware (Mã độc phi tập tin):**
 - Định nghĩa: Mã độc không lưu file trên ổ đĩa mà chạy trực tiếp trong bộ nhớ RAM.
 - Tính chất: Khó phát hiện vì không để lại dấu vết trên ổ đĩa, thường lợi dụng PowerShell, Windows Management Instrumentation (WMI).
 - Nguyên nhân lây nhiễm: Lỗ hổng bảo mật trong phần mềm, macro độc hại trong tài liệu.

Các loại mã độc: Macro Malware



- **Macro Malware (Mã độc sử dụng Macro):**
 - Định nghĩa: Mã độc sử dụng macro trong tài liệu Microsoft Office để thực thi mã độc.
 - Tính chất: Lây nhiễm thông qua file Word, Excel hoặc PowerPoint có macro độc hại.
 - Nguyên nhân lây nhiễm: Email phishing đính kèm tài liệu có macro độc hại.

Các loại mã độc: Botnet



- **Botnet (Mạng lưới máy tính bị nhiễm mã độc bị điều khiển):**
 - Định nghĩa: Một mạng lưới máy tính bị nhiễm mã độc, điều khiển từ xa để thực hiện tấn công.
 - Tính chất: Có thể dùng để phát tán spam, tấn công DDoS, khai thác tiền điện tử...
 - Nguyên nhân lây nhiễm: Lỗ hổng bảo mật, phần mềm độc hại, IoT không được cập nhật...

Các loại mã độc: Logic Bomb



- **Logic Bomb:**

- Định nghĩa: Mã độc chỉ kích hoạt khi điều kiện nhất định xảy ra (ví dụ: vào một ngày cụ thể).
- Tính chất: Có thể ngủ đông trong thời gian dài trước khi tấn công.
- Nguyên nhân lây nhiễm: Tích hợp sẵn trong phần mềm hợp pháp bởi nội gián hoặc hacker.

Các loại mã độc: Cryptojacking



- **Logic Bomb:**

- Định nghĩa: Mã độc sử dụng tài nguyên của nạn nhân để đào tiền điện tử trái phép.
- Tính chất: Gây chậm hệ thống, làm tăng mức sử dụng CPU/GPU.
- Nguyên nhân lây nhiễm: Trình duyệt bị khai thác, tải phần mềm nhiễm mã độc, quảng cáo độc hại.

Các loại mã độc: Malicious LLMs



- **Malicious LLM:**

- Malicious LLMs là các mô hình ngôn ngữ lớn (LLMs) được điều chỉnh hoặc sử dụng để thực hiện các hoạt động độc hại.
- Chúng có thể giúp tin tặc tạo mã độc tự động, viết email lừa đảo (phishing), hoặc thực hiện tấn công kỹ thuật xã hội (social engineering) để đánh cắp thông tin nhạy cảm.
- Một số mô hình LLMs bị lợi dụng hoặc được thiết kế có chủ đích cho mục đích này bao gồm **FraudGPT, WormGPT, Love-GPT.**

Nghiên cứu mã độc: Thách thức



- Đội ngũ chuyên gia quá tải
- Giới hạn về thời gian
- Kẻ tấn công ngày càng thông minh, tinh vi hơn

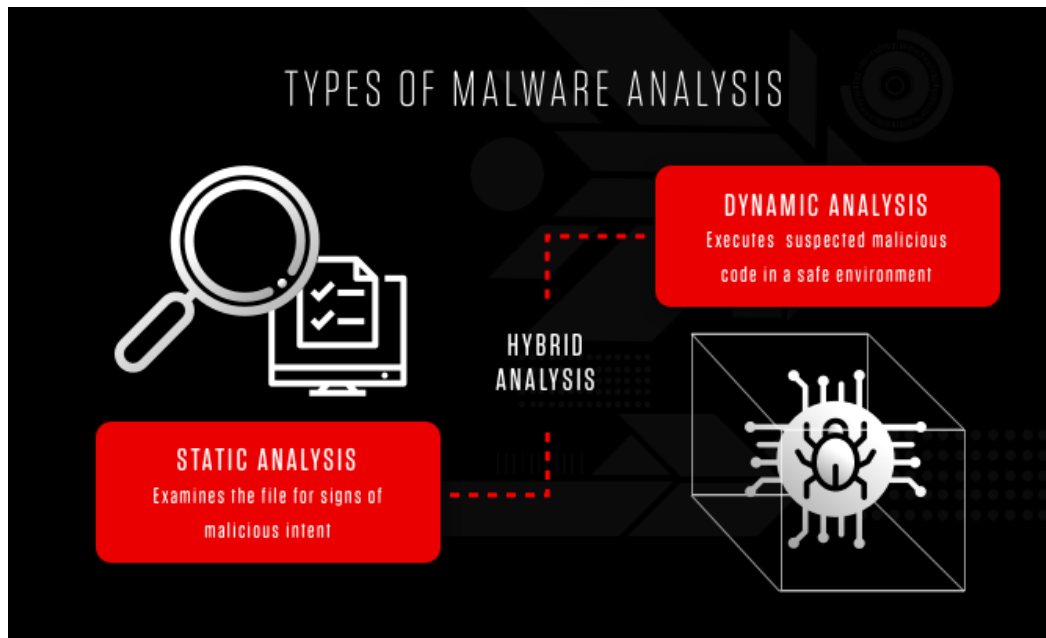


Nguồn: CrowdStrike

Phương pháp Phân tích mã độc

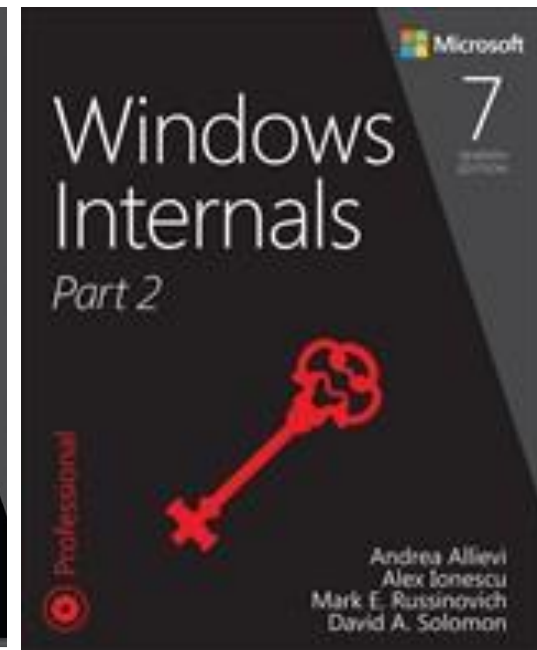
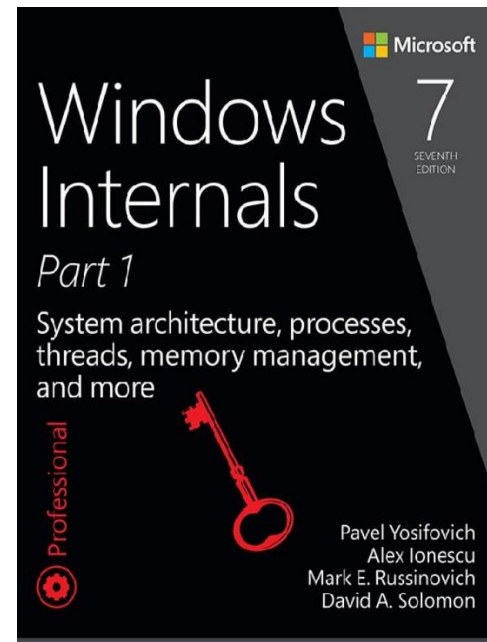
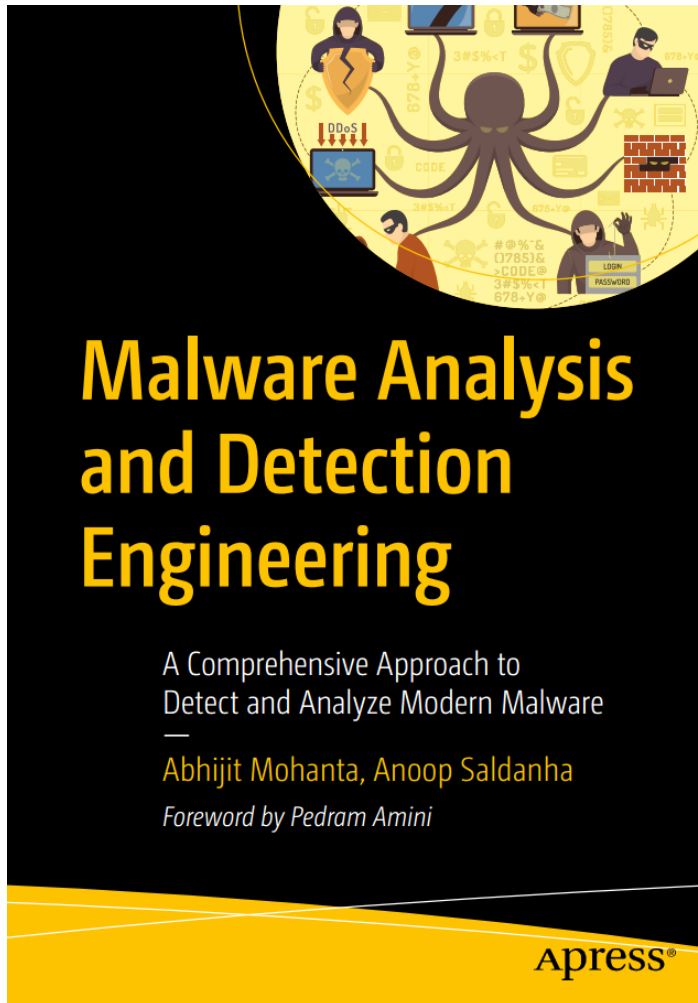


- Phân tích tĩnh
- Phân tích động
- Phân tích lai

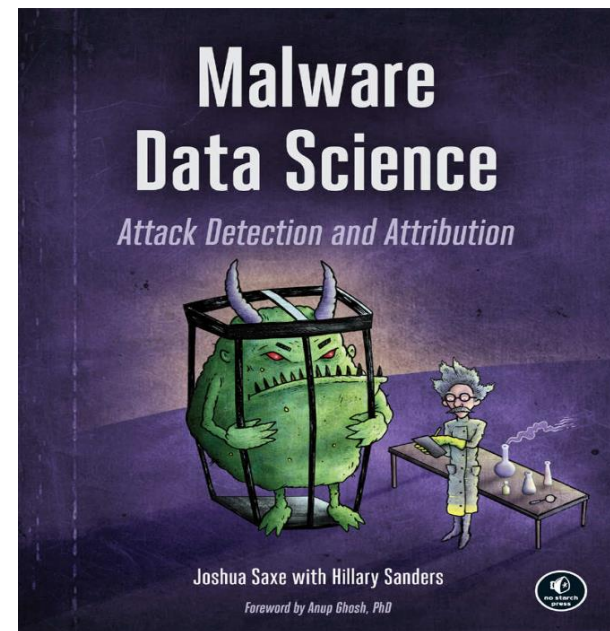
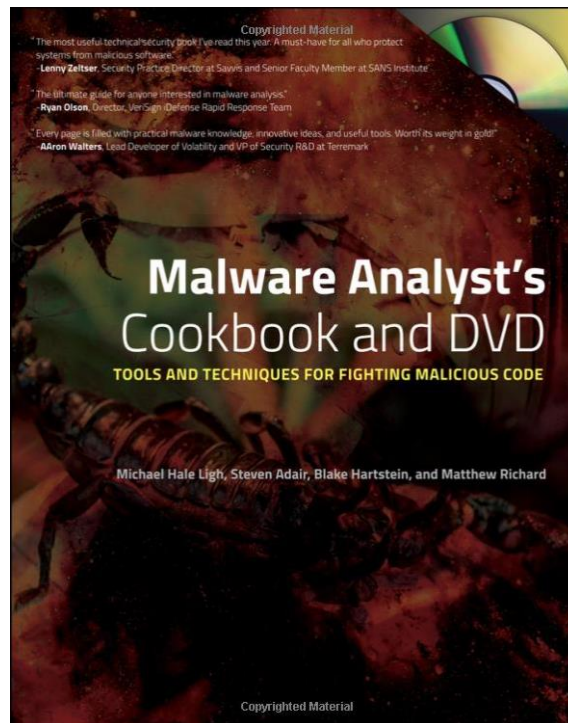
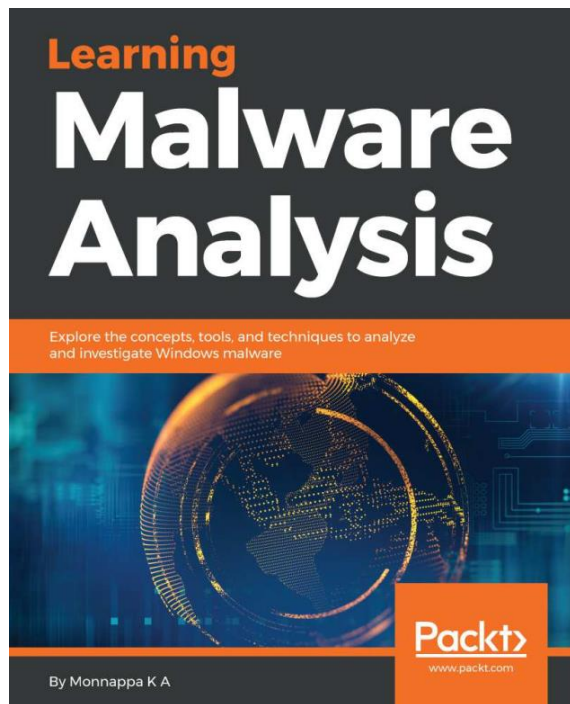


Nguồn: CrowdStrike

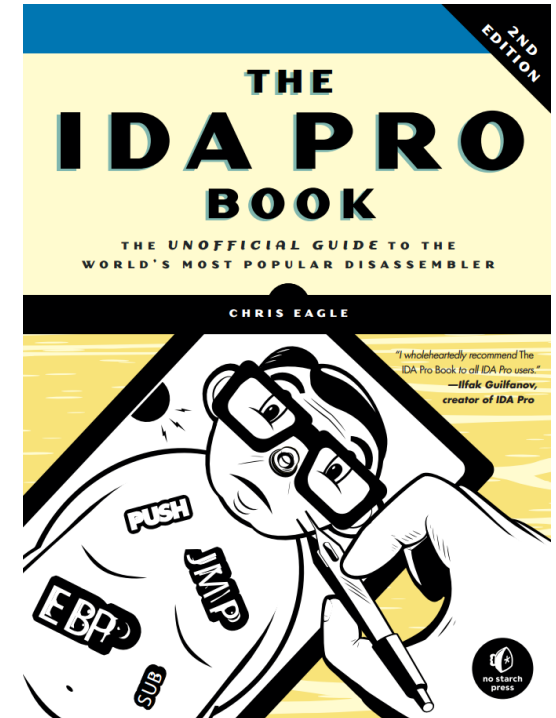
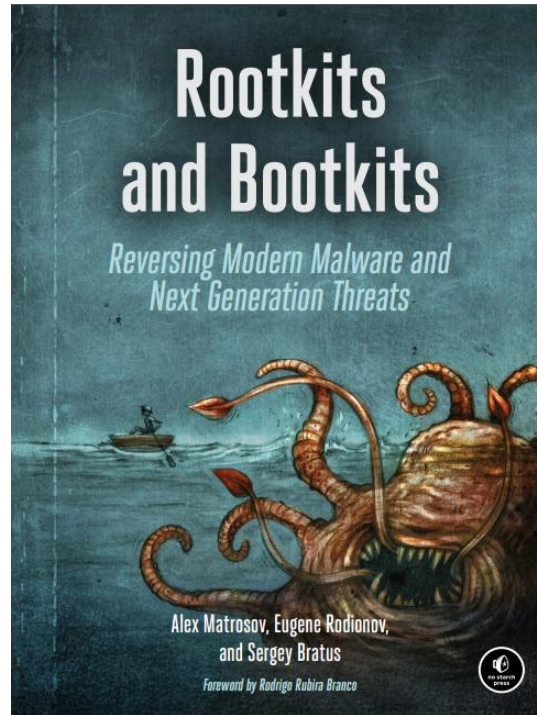
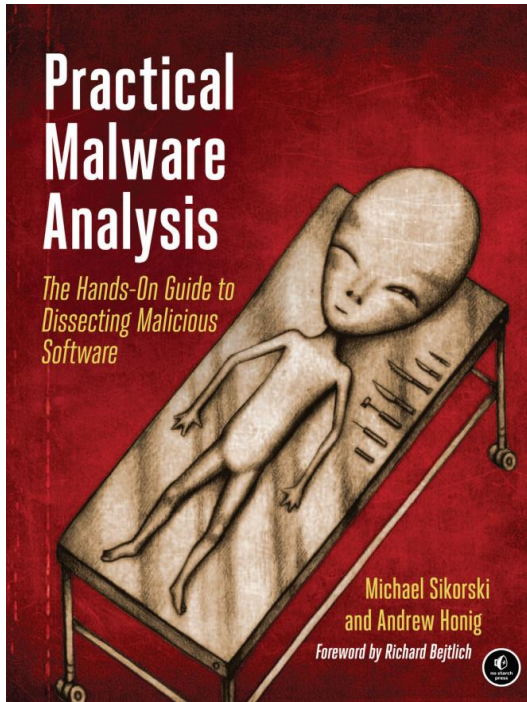
Tài liệu tham khảo



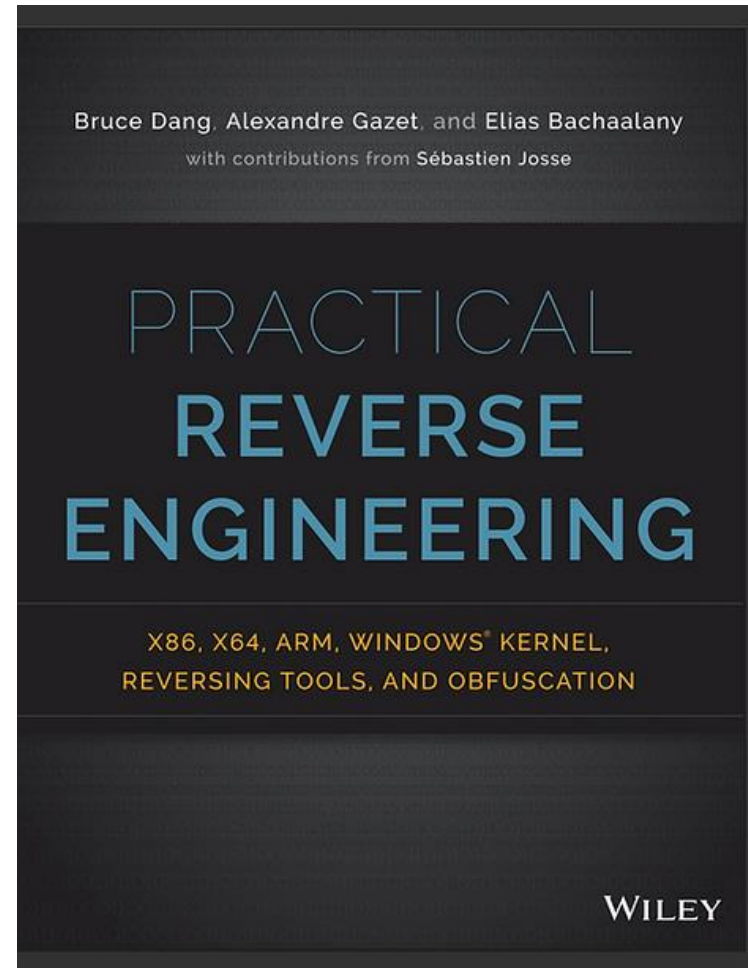
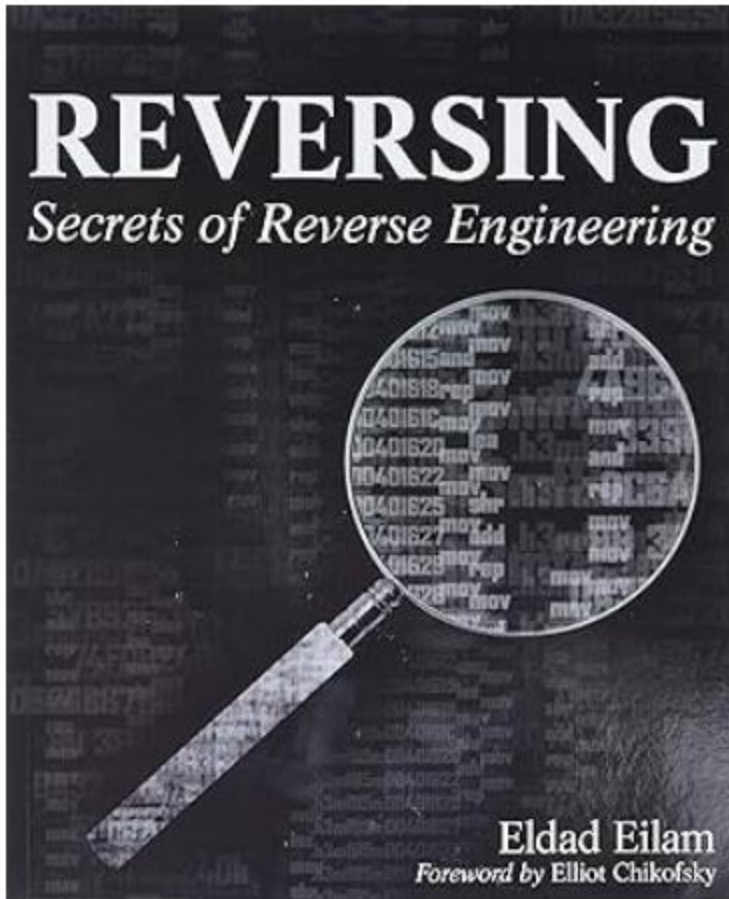
Tài liệu tham khảo



Tài liệu tham khảo



Tài liệu tham khảo



Tài liệu tham khảo



- Website môn học: <https://courses.uit.edu.vn/>
- Thư mục NT230-SharingZone trên OneDrive của môn học (được chia sẻ bởi GV trong quá trình học)
- Một số liên kết hữu ích khác:
 - <https://github.com/x86byte/RE-MA-Roadmap>
 - <https://legend.octopuslabs.io/sample-page.html>
 - <https://blog.virustotal.com/2023/11/how-ai-is-shaping-malware-analysis.html>

Tài liệu tham khảo



The screenshot shows the No Starch Press website catalog for Hacking & Computer Security. The header includes the No Starch Press logo and tagline 'the finest in geek entertainment', a search bar, and navigation links for Catalog, Blog, Media, Write for Us, About Us, and Contact Us. The main content area is titled 'Hacking & Computer Security' and displays a grid of book covers with their titles, authors, and prices. On the left, there is a 'Topics' sidebar with a list of categories and a 'Shopping cart' section showing 0 items for \$0.00. On the right, there is a 'Navigation' section with a 'My account' link and a newsletter sign-up prompt.

no starch press
the finest in geek entertainment

Search

Catalog Blog Media Write for Us About Us Contact Us

Topics

- Art & Design
- General Computing
- Hacking & Computer Security
- Hardware / DIY
- Kids
- LEGO®
- Linux & BSD
- Manga
- Programming
- Python
- Science & Math
- Scratch
- System Administration
- Early Access

Free ebook edition with every print book purchased from nostarch.com!

Shopping cart

0 Items Total: \$0.00

User login

- Log in
- Create account

Hacking & Computer Security

Book Title	Author	Price
A Bug Hunter's Diary	Tobias Klein	\$39.95
Attacking Network Protocols	James Forshaw	\$49.95
Black Hat Python	Justin Seitz	\$34.95
The Car Hacker's Handbook	Craig Smith	\$49.95
Foundations of Information Security	Jason Andress	\$39.95
A Bug Hunter's Diary	Tobias Klein	\$39.95
Attacking Network Protocols	James Forshaw	\$49.95
Black Hat Python	Justin Seitz	\$34.95
The Car Hacker's Handbook	Craig Smith	\$49.95
Foundations of Information Security	Jason Andress	\$39.95
Android Security Internals	Nikolay Elenkov	\$49.95
Black Hat Go	Tom Steele, Chris Patten, and Dan Kottmann	\$39.95
THE BOOK OF PF	Peter N. M. Hansteen	\$34.95
Designing BSD Rootkits	Joseph Kong	\$29.95
Game Hacking	Nick Cano	\$44.95

My account

Want sweet deals?
Sign up for our newsletter.

- Nhà xuất bản No Starch Press có nhiều sách hay về Hacking & Computer Security:
<https://nostarch.com/catalog/security>



NT230 – Malware's Modus Operandi

Cơ chế hoạt động của mã độc

Email: inseclab@uit.edu.vn

Trường ĐH Công nghệ Thông tin -
ĐHQG TP. HCM

